

KRİPTOQRAFIYA KURSU

Mühazirə 24

Açar İdarəçiliyi və PKI

Bu mühazirə açar idarəçiliyinin əsas prinsiplərini, açar həyat dövrünü, PKI (Açıq Açar İnfrastruktur) komponentlərini, X.509 sertifikatlarını, sertifikat mərkəzlərini və ləğv mexanizmlərini əhatə edir.

July 31, 2026

Contents

1	Mühazirənin məqsədləri	3
2	Giriş: Açıq Açarların Həqiqiliyi Problemi	3
3	Açar İdarəçiliyi Problemi və Arxitektura Çətinlikləri	5
3.1	Açar İdarəçiliyinin Fundamental Təhlükəsizlik Məqsədləri	5
3.2	Sistem Səviyyəli İdarəetmə Çətinlikləri	5
4	Açar Həyat Dövrünün Riyazi və Sistem Səviyyəli Analizi	6
4.1	Açar Generasiyası və Entropiya Mənbələri	6
4.2	Açar Paylanması və Post Kvant Təhdidlər	7
4.3	Kriptoqrafik Dualizmin Qadağan Edilməsi (Açar İstifadəsi)	7
4.4	Kriptoqrafik Çeviklik və Açar Rotasiyası	7
4.5	Dinamik ləğv mexanizmləri	7
4.6	Aparat səviyyəsində təhlükəsiz məhv	7
5	PKI – Açıq Açar İnfrastrukturunun Arxitektura Modelləri	8
5.1	PKI-nin Riyazi və Funkisional Məqsədi	8
5.2	PKI-nin Nüvə Komponentləri və Protokol İnterfeysləri	9
5.3	Sertifikat Mərkəzlərinin (CA) Riyazi Funksionallığı və İyerarxiyası	9
5.4	Qeydiyyat Mərkəzlərinin (RA) Administrativ və Təhlükəsizlik Rolu	10
6	X.509 Rəqəmsal Sertifikat Standartı və Məlumat Strukturları	10
6.1	X.509 Standartının Taksonomiyası	10
6.2	X.509 Sintaksisinin Fundamental Sahələri	11
6.3	Versiya 3 Genişləndirmələrinin Semantik Təhlili	11
6.4	Kriptoqrafik Sertifikat Zənciri və Yoxlama Alqoritmi	12
7	Sertifikat Ləğv Mexanizmləri və Şəbəkə Arxitekturası	13
7.1	Sertifikat Ləğv Siyahısı (CRL) və Asinxron Yenilənmə Gecikmələri	13
7.2	OCSP və Real Zamanlı Təhlil	14
7.3	OCSP Bərkidilməsi (RFC 6066) və Kriptoqrafik Çeviklik	14
7.4	Ləğv Mexanizmlərinin Müqayisəli Analizi	15
8	Etibar Modellərinin Topoloji və Funksional Təhlili	16
8.1	Mərkəzləşdirilmiş iyerarxik PKI etibar modeli	16
8.2	Paylanmış Etimad Şəbəkəsi (WoT)	16
8.3	Praktik Tətbiq Sahələri və Müasir Standartlar	17
8.3.1	Müasir TLS/SSL yoxlama növləri və cari vəziyyət	17
8.3.2	E-Poçt Təhlükəsizliyi və Kod İmzalama	17
9	Sənaye Səviyyəli Praktiki Təvsiyələr və Kriptoqrafik Çeviklik	17
10	Nümunə Məsələlər və Çalışmalar	18
11	Müəllim üçün cavab açarı	20

1 Mühazirənin məqsədləri

Bu mühazirəni müvəffəqiyyətlə tamamladıqdan sonra tələbələr:

- verilmiş açar üçün generasiya, aktiv istifadə, rotasiya, arxivləşdirmə və ləğv (məhv) nəzarət mexanizmlərini açarın həyat dövrünə doğru integrasiya etməyi (Menezes et al., 1996);
- PKI strukturu daxilində CA¹, RA², VA³ və məlumat anbarının (*repository*) məsuliyyət zonalarını fərqləndirməyi (Ferguson et al., 2010);
- X.509 sertifikatında subyekt və SAN⁴, sertifikat verən qurum (*Issuer*), etibarlılıq müddəti, açardan istifadə təyinatı və əsas məhdudiyyətlər sahələrini şərh etməyi (Katz and Lindell, 2020);
- sertifikat zənciri üzrə yolun doğrulanması (*path validation*) addımlarını və etibar zənciri üzrə qərar qəbulu prosesini mərhələli təhlil etməyi;
- CRL⁵, OSCP⁶ və OSCP birləşdirməsini (*OCSP stapling*) məlumatın aktuallığı, məxfilik və xəta anındakı reaksiya (*fail-open/fail-close*) xassələri üzrə müqayisə etməyi bacara-caqlar (Paar et al., 2024; Rescorla, 2026).

Kurs xəritəsi və terminologiya kanonu

Əvvəl: 23-cü mühazirə imzanın riyazi yoxlanması mexanizmini təqdim etdi.

İndi: PKI həmin doğrulama açarını identiklik, siyasət və etibar qərarı ilə bağlayır.

Sonra: 25-ci mühazirə sertifikat zəncirinin TLS əl sıxması (*handshake*) daxilində necə istifadə olunduğunu göstərəcəkdir.

Kanon: *sertifikat zənciri* — ötürülən sertifikat obyektlərinin ardıcılığıdır; *etibar zənciri* — etibar edən tərəfin doğrulama qərarıdır; *OCSP təsbitləməsi* (*OCSP stapling*); *seans açarı* (*sessiya açarı*).

2 Giriş: Açıq Açarların Həqiqiliyi Problemi

Əvvəlki mühazirələrimizdə asimmetrik kriptografiyanın fundamental riyazi alqoritmlərini — RSA-nın vuruqlara ayırma çətinliyini, Diffi-Hellman və ElGamal sxemlərinin multiplikativ qru-

¹CA (*Certificate Authority* — Sertifikat Mərkəzi): Rəqəmsal imza vasitəsilə açıq açarları subyektlərin identikliyi ilə bağlayan və X.509 sertifikatlarını imzalamaqla sistemdə əsas etibar nöqtəsi çıxış edən kök və ya aralıq qurumdur.

²RA (*Registration Authority* — Qeydiyyat Mərkəzi): Sertifikat müraciətçilərinin identikliyi və hüquqi müstəvidə səlahiyyətlərini yoxlayan inzibati qurumdur. RA müraciəti təsdiqlədikdən sonra imzalamaq üçün CA-ya ötürür, lakin özü birbaşa sertifikat imzalamır.

³VA (*Validation Authority* — Doğrulama Mərkəzi): Təqdim edilən sertifikatın hal-hazırda etibarlı, yaxud ləğv edilmiş (*revoked*) olduğunu real-vaxt rejimində təsdiqləyən xidmətdir (əsasən OSCP serverləri və ya CRL paylama nöqtələri vasitəsilə).

⁴SAN (*Subject Alternative Name* — Subyektin Alternativ Adı): X.509 sertifikatında tək bir rəqəmsal kimliyə birdən çox domen (*FQDN*), IP ünvanının və ya e-poçtun bağlanmasına imkan verən standart genişlənmədir (*extension*). Müasir HTTPS təhlükəsizlik protokolları uyğunluq doğrulamasını yalnız SAN sahəsi üzrə aparır.

⁵CRL (*Certificate Revocation List* — Sertifikatların Ləğv Siyahısı): CA tərəfindən vaxtından əvvəl ləğv edilmiş etibarsız sertifikatların seriya nömrələrini ehtiva edən, vaxtaşırı rəqəmsal imzalanaraq dərc edilən rəsmi siyahıdır.

⁶OCSP (*Online Certificate Status Protocol* — Onlayn Sertifikat Statusu Protokolu): İstəmcinin konkret sertifikatın etibarlılıq və ləğv statusunu bütün siyahını endirmədən, VA/OCSP serverinə real-vaxt rejimində sorğu göndərərək yoxlamasına imkan verən protokoldur (RFC 6960).

plardakı diskret loqarifm problemini, həmçinin elliptik əyri kriptografiyasını (ECC) ətraflı şəkildə öyrəndik. Bu alqoritmlər bir-biri ilə riyazi olaraq əlaqəli olan açıq və gizli açar cütlərindən istifadə edir. Lakin bu açarların real dünya informasiya sistemlərində etibarlı idarə edilməsi, təhlükəsiz paylanması və ən əsası, sahiblik statusunun təsdiqlənməsi riyazi alqoritmlərin özündən müstəqil, xüsusi bir kriptografik problemdir.

Fundamental Kriptografik Ziddiyyət (MitM Hücumu)

Tutaq ki, Alis Boba asinxron olaraq öz açıq açarını (pk_A) göndərmək istəyir. Bob bu açarı qəbul etdikdə, onun həqiqətən Alisə məxsus olduğunu və kanal üzərində modifikasiya olunmadığını riyazi olaraq necə sübut edə bilər?

Əgər aktiv hücumçu Malori rabitə kanalına nəzarət edərsə, o, Alisin həqiqi pk_A açarını tutur, onu özünün yaradığı saxta pk_M açarı ilə əvəzləyir və Boba ötürür. Bob daxil olan açarı Alisin açarı kimi qəbul edərək mesajları şifrələyir. Nəticədə Malori Bobun mesajlarını oxuyur; bu, ortadakı vasitəçi hücumudur.

Asimmetrik kriptografiyanın riyazi cəhətdən mükəmməl olması, onun açıq kanallarda kimlik doğrulaması olmadan təhlükəsiz işləməsi üçün kifayət deyil. Məhz kimliyin açarla bağlanması problemini həll etmək üçün **Açar İdarəçiliyi** prinsipləri və bu prinsiplərin institusional tətbiqi olan **PKI (Açıq Açar İnfrastruktur)** arxitekturası yaranmışdır. Bu mühazirədə açarların həyat dövrünü, rəqəmsal sertifikatların daxili verilənlər strukturunu, etibar zəncirlərini və müasir şəbəkə təhlükəsizliyi protokollarının əsasını təşkil edən etibar modellərini öyrənəcəyik.

Mühazirə Boyu Cavablandırılacaq Fundamental Suallar

- Açar idarəçiliyi nədir və sistemlərin kriptografik çevikliyi necə təmin edir?
- Açarın həyat dövrü hansı kritik mərhələlərdən ibarətdir və bu mərhələlərin təhlükəsizlik tələbləri nələrdir?
- PKI arxitekturası nədir və onun mərkəzi komponentləri (CA, RA, CRL, VA) hansı funksiyaları yerinə yetirir?
- X.509 standartlı rəqəmsal sertifikat nədir və onun daxilindəki məlumatlar asimmetrik təhlükəsizliyi necə formalaşdırır?
- Sertifikat Mərkəzləri (CA) iyerarxiyası necə qurulur və etimad zənciri brauzerlər tərəfindən necə yoxlanılır?
- Ləğv edilmiş sertifikatların monitorinqi necə aparılır? CRL siyahılarının genişlənmə problemi və OCSP protokolunun real zamanlı sorğu mexanizmi necə işləyir?
- **OCSP bərkidilməsi** nədir, o, istifadəçinin məxfiliyinə olan hücumları və veb-performans ləngimələrini necə həll edir?
- Mərkəzləşdirilmiş iyerarxik etibar modeli ilə paylanmış etimad şəbəkəsi arasındakı riyazi, sosial və funksional fərqlər nələrdir?

3 Açar İdarəçiliyi Problemi və Arxitektura Çətinliklər

Kriptografik sistemlərin ümumi təhlükəsizliyi istifadə olunan alqoritmlərin riyazi mürəkkəbliyindən daha çox, bu alqoritmləri qidalandıran açar materiallarının necə idarə olunmasından asılıdır. Kerckhoffs prinsipinin fundamental fərziyyəsinə görə, hücumçu alqoritmin bütün daxili strukturuna bələddir; sistemin gizliliyi rəqəmsal olaraq yalnız və yalnız açarın gizliliyinə söykənir (Stinson and Paterson, 2018).

3.1 Açar İdarəçiliyinin Fundamental Təhlükəsizlik Məqsədləri

Effektiv bir açar idarəetmə sistemi (KMS) informasiya təhlükəsizliyinin klassik triadası ilə yanaşı, spesifik kriptografik atributları da təmin etməlidir:

- **Məxfilik:** Gizli və ya xüsusi açar materialları həyat dövrünün heç bir mərhələsində səlahiyyətsiz subyektlərə sızmamalıdır. Bu məqsədlə HSM və ya TEE kimi aparat səviyyəli təcrid mühitlərindən istifadə olunur.
- **Bütövlük və autentifikasiya:** Açarların tərkibindəki bit ardıcılığı icazəsiz dəyişikliklərdən qorunmalıdır. Açıq açarla identifikator arasındakı uyğunluq isə seçilmiş qeydiyyat və sertifikat siyasətinə əsasən sertifikat verən tərəfin imzaladığı iddia kimi yoxlanılır; bu imza öz-özlüyündə fiziki şəxsin kimliyini riyazi olaraq sübut etmir və avtomatik hüquqi inkaredilməzlik yaratmır (Menezes et al., 1996).
- **Mövcudluq və Davamlılıq:** Şifrələnmiş məlumatların oxunması və ya rəqəmsal imzaların yoxlanılması üçün lazımi açar materialları zədələnməyə və sistem qəzalarına qarşı ehtiyatlı və yüksək əlçatan olmalıdır.
- **Kriptografik Yoxlanıla Bilmə:** Açarların generasiyası, paylanması, aktivləşdirilməsi və ləğvi kimi bütün kritik əməliyyatlar gələcək ekspertiza və təhlükəsizlik təhlilləri üçün kriptografik olaraq qorunan, dəyişiklikləri aşkarlanan qeyd jurnallarında saxlanmalıdır.

3.2 Sistem Səviyyəli İdarəetmə Çətinlikləri

Açar idarəçiliyi infrastrukturalarının real dünya şəbəkələrində tətbiqi riyazi, logistik və arxitektura xarakterli bir sıra çətinliklərlə qarşılaşır:

1. **Miqyaslanma Problemi:** Sırf simmetrik kriptografiyaya əsaslanan N sayda istifadəçidən ibarət olan şəbəkədə hər istifadəçi cütü üçün unikal bir gizli açar tələb olunur ki, bu da cəmi $N(N - 1)/2$ sayda açarın idarə edilməsi deməkdir ($O(N^2)$ mürəkkəblik). İstifadəçi sayı milyonlara çatdıqda bu model tamamilə iflas edir və idarəetmə mürəkkəbliyini $O(N)$ tərtibinə endirən asimetrik infrastrukturlara (PKI) keçidi məcburi edir.
2. **Açar Ömrü və Dövri Yenilənmə:** Bir açarla həddindən artıq verilənlərin şifrələnməsi hücumçuya kriptozanaliz üçün kifayət qədər material (məsələn, statistik asılılıqlar) verir. Bu səbəbdən açarların mütəmadi olaraq dəyişilməsi lazımdır. Çətinlik isə köhnə açarla şifrələnmiş arxiv məlumatlarının əlçatanlığını qorumaqla yeni açara problemsiz keçməkdir.
3. **Açarın ələ keçirilməsi və dinamik ləğv:** Bir gizli açarın sızması və ya ələ keçirilməsi şübhəsi yarandıqda, həmin açarla bağlı bütün əməliyyatlar dərhal dayandırılmalıdır. Geniş paylanmış sistemlərdə bir açarın ləğv olunduğu barədə məlumatı bütün qovşaqlara cari vaxtda ötürmək ən böyük şəbəkə və sinxronizasiya çətinliklərindən biridir.

4. **Açarın bərpası və etibarlı saxlayıcı ziddiyyəti:** İstifadəçinin gizli açarı itdikdə şifrəli məlumatların həmişəlik əlçatmaz olmaması üçün xüsusi bərpa mexanizmi tələb oluna bilər. Lakin açarın üçüncü tərəfdə saxlanması daxili təhdid və arxa qapı riskini artırır.
5. **İrəli məxfilik (FS):** Müasir arxitekturalardan tələb olunur ki, bu gün sızan uzunmüddətli gizli açar keçmiş sessiyaların və ya verilənlərin açılmasına şərait yaratmasın. Bu prinsipin KMS səviyyəsində avtomatlaşdırılması hər sessiya üçün təzə müvəqqəti açar mexanizmləri tələb edir.

4 Açar Həyat Dövrünün Riyazi və Sistem Səviyyəli Analizi

Kriptoqrafik açarlar statik verilənlər strukturu deyil; onlar yaradıldıqları andan etibarən tam məhv edilənə qədər ciddi şəkildə nizamlanmış və nəzarət olunan bir həyat dövrü keçirlər. Bu dövrün hər bir mərhələsi spesifik standartlar (məsələn, NIST SP 800-57) və hücum modelləri çərçivəsində idarə olunur (Ferguson et al., 2010).



Şəkil 1: Kriptoqrafik açar həyat dövrünün vəziyyət keçidləri.

4.1 Açar Generasiyası və Entropiya Mənbələri

Açar generasiyası bütün kriptosistemin təhlükəsizlik təməlidir. Riyazi olaraq, bir açar fəzasından (K) seçilən açarın hücumçu tərəfindən təxmin edilmə ehtimalı minimallaşdırılmalıdır (Stallings, 2017).

- **Entropiya Tələbi:** Sistemlərdə təsadüfiliyi təmin etmək üçün fiziki xaos əsaslı həqiqi təsadüfi ədədlər generatorlarından (TRNG; məsələn, istilik küyü və ya radioaktiv parçalanma) və ya NIST SP 800-90A standartlı deterministik psevdo-təsadüfi ədədlər generatorlarından (DRBG/PRNG) istifadə edilməlidir.
- **Asimmetrik Açarların Spesifikasiyası:** RSA üçün generasiya prosesi təkcə təsadüfiliyi deyil, həm də böyük sadə ədədlərin (p, q) generasiyasını tələb edir. Bu ədədlər təsadüfi seçildikdən sonra mütləq yüksək dərəcəli deterministik və ehtimallı Miller-Rabin sadəlik testlərindən keçirilməlidir (Katz and Lindell, 2020).

4.2 Açar Paylanması və Post Kvant Təhdidlər

Yaradılmış açar materialının gizlilik və bütövlüyü qorunmaqla təyinat nöqtəsinə çatdırılması açar mübadiləsi problemini doğurur (Menezes et al., 1996).

- **Simmetrik Arxitekturalarda:** Paylanma ya fiziki olaraq tam təhlükəsiz mühitdə (məsələn, ağillı kartlar, HSM daşıyıcıları) həyata keçirilir, ya da Diffi-Hellman (DH/ECDH) asimmetrik sxemləri vasitəsilə açıq kanal üzərində ortaq sessiya açarı formalaşdırılır. Böyük müəssisələrdə isə mərkəzləşdirilmiş Kerberos tipli açar paylama mərkəzlərindən (KDC) istifadə olunur.
- **Asimmetrik Arxitekturalarda:** Açıq açarların (pk) məxfiliyinə ehtiyac olmadığı üçün onlar sərbəst yayıla bilər, lakin onların autentifikasiyası mütləqdir. Bu məqsədlə rəqəmsal sertifikatlardan və ya mərkəzləşdirilməmiş açıq açar xidmətlərindən istifadə edilir.

4.3 Kriptoqrafik Dualizmin Qadağan Edilməsi (Açar İstifadəsi)

Hər bir açar unikal kriptoqrafik istifadə siyasətinə malik olmalıdır.

Eyni Açarın Multi-Funksional İstifadəsi Riski

Bir asimmetrik açar cütünün həm rəqəmsal imza, həm də şifrələmə üçün eyni anda istifadə edilməsi yolverilməzdir.

Bəsit RSA nümunəsi: Eyni bəsit RSA çevrilməsi həm imza, həm də deşifrələmə sorğuları üçün istifadə edilsəydi, hücumçu şifrəli mətn nümayəndəsini “mesaj” kimi imzaladaraq $C^d \bmod n$ ala bilərdi. Müasir RSASSA və RSAES/KEM sxemləri fərqli sahə ayırıcılarından, kodlaşdırmadan və proqram interfeyslərindən istifadə edir; imza interfeysi ixtiyari RSA nümayəndəsini qəbul etməməlidir. Açarların ayrılması səhv salamanın, protokollararası hücumun və açar sızmasının təsirini məhdudlaşdıran əsas mühəndislik qaydasıdır.

4.4 Kriptoqrafik Çeviklik və Açar Rotasiyası

Açarların müəyyən edilmiş istifadə müddətində dəyişdirilməsi prosesinə dövrü yenilənmə deyilir. NIST SP 800-57 universal “açar növü → sabit il sayı” cədvəli vermir; istifadə müddəti açarın məqsədi, qorunan məlumatın ömrü, istifadə həcmi, kompromet təsiri və yenilənmə imkanları üzrə risk qiymətləndirməsi ilə seçilir (Barker, 2020):

4.5 Dinamik ləğv mexanizmləri

Ləğv prosesi — açarın təbii ömrünün bitməsinə gözləmədən, onun etibarlılıq statusunun dərhal ləğv edilməsidir. Bu proses mərkəzləşdirilmiş sistemlərdə PKI-in ən çətin infrastrukturunu olan **CRL** və **OCSP** infrastrukturunu tərəfindən idarə olunur. Bu mexanizmlərin daxili memarlığı növbəti bölmələrdə ətraflı təhlil ediləcəkdir.

4.6 Aparat səviyyəsində təhlükəsiz məhv

Həyat dövrünün son mərhələsi açarın sistemdən tamamilə təmizlənməsidir. Sadə bir `free()` və ya `delete` əmri əməliyyat sistemi və RAM/qoşma yaddaş səviyyəsində qalıq verilənlər sız

Obyekt	Seçim əsası	Qeyd
Sessiya açarı	Sessiya/protokol limiti və məlumat həcmi	Müvəqqəti sirr istifadə bitdikdə silinir
Baş açar/KEK	KMS risk təhlili, təftiş və yenidən bükmə imkanı	Aktiv və yalnız deşifrəlmə dövrləri ayrı ola bilər
İmza və deşifrəlmə açarı	Təhlükəsizlik gücü, məlumat ömrü, kompromet təsiri	Açarın istifadə müddəti sertifikatın etibarlılıq müddəti deyil
Publik TLS əbunəçi sertifikatı	CA/Browser Forum-un Baza Tələbləri (<i>Baseline Requirements</i>)	15 mart 2026-dan verilən sertifikat üçün maksimum 200 gün (CA/Browser Forum, 2026)

Cədvəl 1: Müasir standartlara uyğun kriptografik açar ömürləri.

bilər; bu isə soyuq yükləmə hücumu ilə açarın yaddaşdan bərpa olunmasına şərait yaradır (Menezes et al., 1996).

Təhlükəsiz Məhv Standartları:

- **Sıfırlama:** FIPS 140-3 üzrə təsdiqlənmiş modul həssas təhlükəsizlik parametrlərini öz təhlükəsizlik siyasətində göstərilən və daşıyıcıya uyğun üsulla məhv etməlidir. Bir neçə dəfə sıfır və ya təsadüfi məlumat yazmaq bütün RAM, fleş yaddaş, SSD və HSM-lər üçün universal tələb deyil.
- **Aparat səviyyəli həll:** Bəzi HSM və çip kartları fiziki müdaxilə hadisəsində açar materialını silir, lakin mexanizm və zamanət konkret modulun dizaynı və təsdiqlənmiş təhlükəsizlik siyasəti ilə yoxlanmalıdır.

5 PKI – Açıq Açar İnfrastrukturunun Arxitektura Modelləri

Açıq açar infrastruktur (PKI) sertifikat verən tərəfin müəyyən yoxlama siyasətindən sonra subyektlər və açıq açar barədə imzalanmış iddianı yayımladığı idarəetmə çərçivəsidir (Stallings, 2017). CA imzası iddianın bütövlüyünü qoruyur; inzibati identifikasiya prosesini riyazi fakta və ya avtomatik hüquqi inkaredilməzliyə çevirmir.

5.1 PKI-nin Riyazi və Funkisional Məqsədi

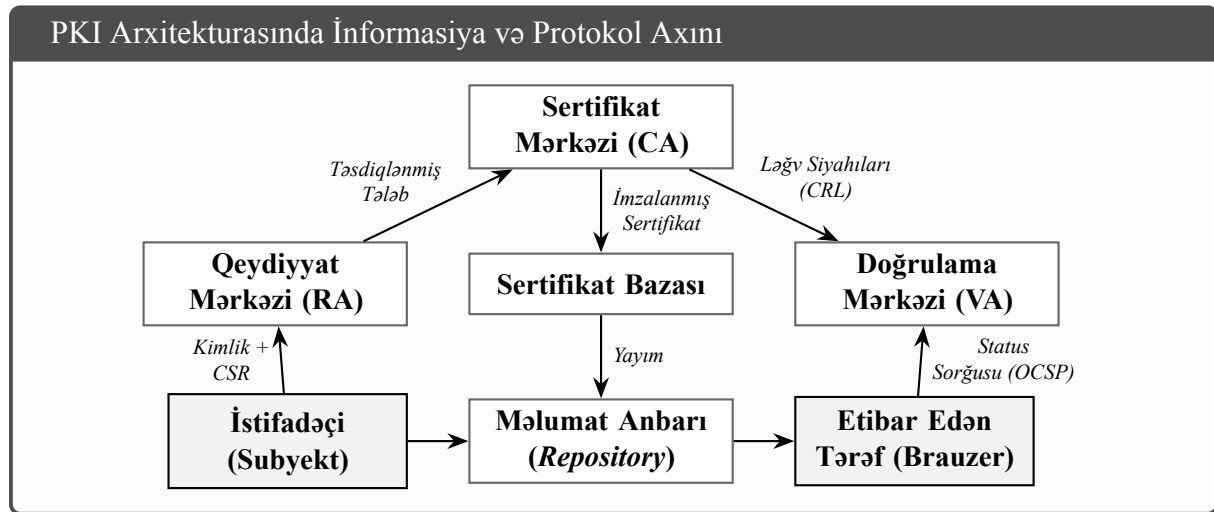
PKI formal olaraq aşağıdakı riyazi və sistem invariantlarını təmin etmək üçün layihələndirilir:

- **Açıq açar iddiası:** Sertifikat verən tərəfin siyasət və yoxlama proseduru daxilində ID_A ilə pk_A arasındakı bağın imzalanması və sertifikata güvənən tərəf tərəfindən qiymətləndirilməsi.
- **Audit və hüquqi sübut:** Sertifikat, açara sahiblik sübutu, açar qorunması, zaman və audit qeydlərinin hüquqi və əməliyyat prosesinə dəlil verməsi; nəticə avtomatik deyil.
- **Kriptografik Çeviklik və Həyat Dövrü Avtomatlaşdırılması:** Milyonlarla istifadəçidən ibarət paylanmış şəbəkələrdə açarların generasiyası, paylanması və ləğvi proseslərinin vahid standartlar (məsələn, RFC 5280) əsasında avtomatlaşdırılması (Ferguson et al., 2010).

5.2 PKI-nin Nüvə Komponentləri və Protokol İnterfeysləri

Müasir bir PKI arxitekturası sadəcə proqram təminatından ibarət deyil; o, funksional olaraq izolyasiya edilmiş alt sistemlərin koordinasiya fəaliyyətini tələb edir:

1. **Sertifikat mərkəzi (CA):** Açıq açar və kimlik məlumatı barədə iddianı öz gizli açarı ilə imzalayaraq rəqəmsal sertifikata çevirən orqan. Etibar lövbəri isə sertifikat yolunu yoxlayan sistemin əvvəlcədən güvəndiyi ayrıca başlanğıc nöqtəsidir.
2. **Qeydiyyat Mərkəzi (RA):** İstifadəçi ilə CA arasında inzibati interfeysdir. Kimlik yoxlamasını həyata keçirir, lakin kriptografik imzalama səlahiyyəti yoxdur.
3. **Status yoxlama mərkəzi (VA):** Sertifikatların cari statusunu (etibarlı, ləğv edilmiş və ya naməlum) yoxlayan və müştərilərə OCSP/CRL vasitəsilə cavab verən komponent.
4. **Repozitoriyalar və Qovluq Xidmətləri:** Aktiv sertifikatların və CRL siyahılarının kütləvi əlçatanlığını təmin edən paylanmış verilənlər bazaları (məsələn, LDAP və ya HTTP serverləri).
5. **Sertifikat siyasəti (CP) və sertifikatlaşdırma təcrübəsi bəyanatı (CPS):** İnfrastrukturun hüquqi, texniki və əməliyyat sərhədlərini, eləcə də risk idarəçiliyini müəyyən edən formal siyasət sənədləri (Katz and Lindell, 2020).



Şəkil 2: PKI komponentləri arasında rəsmi müraciət və məlumat mübadiləsi topoqrafiyası.

5.3 Sertifikat Mərkəzlərinin (CA) Riyazi Funksionallığı və İyerarxiyası

Tərif 5.1 (Sertifikat Mərkəzi). *Sertifikat Mərkəzi (CA), bir subyektin kimlik məlumatlarını (ID_A) və onun açıq açarını (pk_A) ehtiva edən imzalanacaq TBS verilənlər blokunu öz gizli açarı (sk_{CA}) vasitəsilə kriptografik olaraq imzalayan etibarlı bir kriptosistem qovşağıdır:*

$$S_A = \text{Sign}_{sk_{CA}}(\text{TBSertificate}(ID_A, pk_A, \text{Valid-Period}))$$

CA-nın İyerarxik Topologiyası: Real dünya tətbiqlərində təhlükəsizlik risklərini bölüşdürmək üçün çoxsəviyyəli etibar zəncirlərindən istifadə olunur (Stallings, 2017):

- **Kök CA:** Etibar zəncirinin zirvəsidir. Onun sertifikatı öz-özünü imzalayandır ($sk_{kök}$ ilə imzalanır). Kök CA-nın gizli açarı demək olar ki, həmişə şəbəkədən tam təcrid olunmuş, fiziki olaraq ən yüksək səviyyədə qorunan HSM daxilində saxlanılır.
- **Aralıq CA:** Kök CA və ya digər yuxarı səviyyəli aralıq CA tərəfindən imzalanan qurumlardır. Əməliyyat səviyyəsində son istifadəçilərə sertifikatların verilməsi və ləğvi birbaşa bu CA-lar tərəfindən icra olunur. Beləliklə, hər hansı bir aralıq CA kompromat olarsa, Kök CA sadəcə həmin budağı ləğv edir və ümumi infrastruktur qorunub saxlanılır.

5.4 Qeydiyyat Mərkəzlərinin (RA) Administrativ və Təhlükəsizlik Rolu

RA qeydiyyat və inzibati yoxlama rolunu yerinə yetirir. İstifadəçinin yaratdığı imza açarlarında RA/CA yalnız açıq açarı və gizli açara sahiblik sübutunu görür. Mərkəzləşdirilmiş açar yaratma, etibarlı saxlama və bərpa profillərində isə səlahiyyətli sistem şifrələmə açarını yarada və ya qoruya bilər; imza və şifrələmə açarı siyasətləri ayrılmalıdır (Menezes et al., 1996).

RA-nın Proses Modeli:

- İstifadəçi öz mühitində (HSM, çip kartı və ya proqram təminatı) unikal (pk, sk) açar cütünü yaradır.
- İstifadəçi pk açarını və kimlik məlumatlarını daxil edərək bir **sertifikat imzalama sorğusu (CSR)** faylı (məsələn, PKCS#10 standartında) formalaşdırır. Bu sorğu istifadəçinin gizli açarı ilə imzalanır və CA/RA-ya istifadəçinin həmin açara həqiqətən sahib olduğunu sübut edir (PoP).
- RA istifadəçinin hüquqi sənədlərini (şəxsiyyət vəsiqəsi, domen sahibliyi protokolları və s.) yoxlayır.
- Şəxsiyyət təsdiqləndikdən sonra RA bu CSR sorğusunu təhlükəsiz protokol (məsələn, CMP – RFC 4210) vasitəsilə CA-ya ötürür.

6 X.509 Rəqəmsal Sertifikat Standartı və Məlumat Strukturları

6.1 X.509 Standartının Taksonomiyası

X.509 ITU-T tərəfindən idarə olunur və RFC 5280 Internet PKI profilini müəyyən edir (Stallings, 2017). TLS, IPsec və S/MIME profillərində geniş istifadə olunur. SSH isə standart halda birbaşa qovşaq açarlarından, `known_hosts` faylından və öz sertifikat formatından istifadə edir; X.509 əsas SSH modelinin məcburi nüvəsi deyil.

Tərif 6.1 (X.509 Sertifikatı). *X.509 sertifikatı – bir subyektin real dünya kimlik atributlarını, yəni seçilən adını (DN), onun kriptografik açıq açarı (pk) ilə assosiasiya edən və bu assosiasiyanın bütövlüyünü etibarlı bir CA-nın rəqəmsal imzası ($Sign_{sk_{CA}}$) vasitəsilə təmin edən formal, kriptografik olaraq qorunan verilənlər strukturudur.*

Akademik olaraq qeyd edilməlidir ki, X.509 sertifikatları maşın tərəfindən oxunub-anlaşıla bilən formal **ASN.1** dili vasitəsilə təsvir olunur və şəbəkə üzərindən ötürülməzdən və ya yaddaşda saxlanılmazdan əvvəl bayt ardıcılığına çevrilmək üçün **DER** ikili kodlaşdırma qaydalarına tabe edilir.

6.2 X.509 Sintaksisinin Fundamental Sahələri

Müasir sistemlərdə istifadə olunan X.509 v3 formatı ciddi şəkildə iyerarxikləşdirilmiş sahələrdən ibarətdir (Ferguson et al., 2010):

Sintaktik Sahə (ASN.1)	Terminoloji Qarşılığı	Kriptoqrafik və Sistem Rolu
version	Versiya	Sertifikatın struktur arxitekturasını göstərir. Müasir sistemlərdə genişlənmələri dəstəkləyən Versiya 3 (0x02) istifadə olunur.
SerialNumber	Seriya Nömrəsi	CA tərəfindən hər bir sertifikata təyin edilən unikal tam ədəd (<i>Integer</i>). Kriptoqrafik olaraq Entropiyalı təyin edilməlidir.
signature	İmza alqoritmi	Sertifikatın TBS strukturunu imzalamaq üçün CA-nın istifadə etdiyi kriptoqrafik alqoritm identifikatoru (məsələn, sha256WithRSAEncryption, ecdsa-with-SHA256).
issuer	Sertifikat verən tərəf	Sertifikatı yaradan və imzalayan CA-nın X.500 standartlı fərqləndirilmiş adı (DN).
Validity	Etibarlılıq Müddəti	Sertifikatın müvafiq olaraq aktivləşdiyi (notBefore) və qüvvədən düşdüyü (notAfter) zaman pəncərəsi.
subject	Subyekt (sahib)	Açıq açarın aid olduğu qurumun (məsələn, CN=example.com, O=Universitet, C=AZ) rəsmi kimliyi.
subjectPublicKeyInfo	Açıq Açar Məlumatı	Ən kritik sahədir. Subyektin açıq açar bitlərini və bu açarın aid olduğu alqoritm (məsələn, RSA, ECC) parametrlərini ehtiva edir.
issuerUniqueID / subjectUniqueID	Unikal identifikatorlar	Versiya 2-də təqdim edilmiş, eyni DN adına malik fərqli qurumları ayırd etmək üçün istifadə olunan, lakin v3-də demək olar ki, tətbiq edilməyən sahələr.
extensions	Genişləndirmələr	Versiya 3-ün nüvəsidir. Sertifikata semantik və funksional məhdudiyyətlər/atributlar əlavə etməyə imkan verən dinamik struktur.

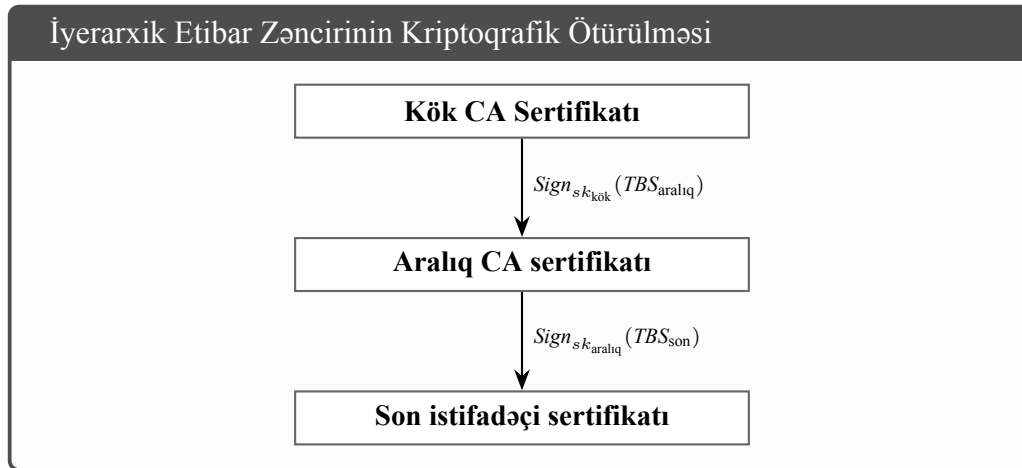
6.3 Versiya 3 Genişləndirmələrinin Semantik Təhlili

X.509 v3 genişlənmələri sertifikatın istifadə sahəsini məhdudlaşdırmaq və hücum vektorlarını minimallaşdırmaq üçün kritik əhəmiyyət kəsb edir. Hər bir genişlənmə **kritik** və ya **qeyri-kritik** olaraq işarələnir. Əgər tətbiq kritik olaraq işarələnmiş genişlənməni oxuya və ya emal edə bilmirsə, həmin sertifikatı dərhal rədd etməlidir (Stinson and Paterson, 2018).

- **Əsas məhdudiyyətlər (kritik):** Sertifikatın digər sertifikatları imzalamaq səlahiyyətinin (isCA: TRUE/FALSE) olub-olmadığını təyin edir. Həmçinin zəncirin maksimal dərinliyini (pathLenConstraint) məhdudlaşdırır.
- **Açar istifadəsi (kritik):** Açarın kriptografik səviyyədə hansı primitivlərə icazə verdiyini təyin edir: digitalSignature (kimlik doğrulaması), keyEncipherment (asimmetrik açar şifrələməsi) və ya cRLSign (ləğv siyahılarını imzalamaq).
- **Genişləndirilmiş açar istifadəsi (EKU):** Açara daha konkret tətbiq rolları verir (məsələn, yalnız TLS veb-server autentifikasiyası və ya yalnız kod imzalama).
- **Alternativ subyekt adı (SAN):** Klassik ümumi ad (CN) sahəsinin məhdudiyyətlərini aradan qaldırır; sertifikatın eyni anda bir neçə domen adına (DNS), IP ünvanına və ya e-poçt ünvanına bağlanmasını təmin edir.
- **Səlahiyyət açarı identifikatoru (AKI) və subyekt açarı identifikatoru (SKI):** Uyğun olaraq imzalayan CA-nın və subyektin açar heşlərini saxlayır. Bu identifikatorlar nəhəng sertifikat bazalarında etibar zəncirinin qrafını qurmaq üçün indeks rolunu oynayır.
- **CRL paylama nöqtələri (CDP) və səlahiyyət məlumatına çıxış (AIA):** Brauzerlərə bu sertifikatın vəziyyətini yoxlamaq üçün CRL yükləmə ünvanını və cari OCSP sorğularının göndəriləcəyi VA ünvanını göstərir.

6.4 Kriptografik Sertifikat Zənciri və Yoxlama Alqoritmi

Real dünya PKI arxitekturalarında son istifadəçilər kök sertifikat mərkəzi tərəfindən birbaşa imzalanmır. Bunun əvəzinə, etibarın ötürülməsi prinsipinə söykənən bir iyerarxik zəncir formalaşdırılır (Stallings, 2017).



Şəkil 3: Kökdən yarpağa doğru kriptografik imza zəncirinin formalaşması sxemi.

Sertifikat yolunun qurulması və yoxlanması: Yolun qurulması mümkün sertifikat verən tərəflərdən yerli etibar lövbərinə⁷ namizəd yol yaradır. RFC 5280 üzrə yol yoxlaması isə seçilmiş yolu tətbiqin giriş verilənləri və yerli siyasətlə yoxlayır (Cooper et al., 2008):

⁷Etibar lövbəri (*Trust Anchor*): Sertifikat zəncirinin doğrulandığı və sistem tərəfindən ilkin olaraq tam etibarlı qəbul edilən kök sertifikat (*Root Certificate*) və ya açıq açardır.

1. Etibar lövbəri sertifikat yolunun xaricində yerli giriş veriləni kimi seçilir; onun öz imzası etibar yaratmır və lövbər sertifikat biçimində olmaya bilər.
2. Hər sertifikatın verən tərəf/subyekt əlaqəsi, imzası, etibarlılıq müddəti və tanınmayan kritik genişlənmələri yoxlanılır.
3. Aralıq CA-lar üçün `basicConstraints`, `keyUsage`, `pathLenConstraint`, ad məhdudiyyətləri (*name constraints*) və qayda ağacı (*policy tree*) emal edilir; istifadə olunan alqoritm və açar uzunluğu yerli qayda tələblərinə cavab verməlidir.
4. Yarpaq sertifikatının ECU və açar istifadəsi tətbiq məqsədinə uyğun olmalı, TLS üçün istənilən qovşaq adı SAN ilə yoxlanmalıdır.
5. Ləğv etmə və xəta zamanı davam etmə davranışı sertifikat imzası yolundan ayrıca müştəri və ekosistem qaydası ilə tətbiq olunur.

7 Sertifikat Ləğv Mexanizmləri və Şəbəkə Arxitekturası

Sertifikatın etibarlılıq müddətinin davam etməsinə baxmayaraq, subyektin gizli açarının kompromat olması, təşkilati dəyişikliklər və ya CA-nın öz fəaliyyətini dayandırması subyekt sertifikatının dərhal ləğv edilməsini tələb edir. PKI arxitekturasında ləğv statusunun paylanması paylanmış sistemlərin konsensus və gecikmə problemlərini doğurur (Paar et al., 2024).

7.1 Sertifikat Ləğv Siyahısı (CRL) və Asinxron Yenilənmə Gecikmələri

Tərif 7.1 (CRL). *Sertifikat ləğv siyahısı (CRL), RFC 5280 standartına uyğun olaraq, CA tərəfindən kriptografik olaraq imzalanan, unikal seriya nömrələri vasitəsilə identifikasiya edilən və vaxtından əvvəl etibarsız sayılmış aktiv sertifikatların zaman damğalı siyahısıdır.*

CRL Arxitektur Sahələrinin Struktur Analizi:

- `thisUpdate`: Siyahının CA tərəfindən imzalandığı və qüvvəyə mindiyi dəqiq UTC zamanı.
- `nextUpdate`: Növbəti periodik CRL-in yayımlanacağı son xətt. Müştərilər bu zamana qədər lokal keşdə olan CRL-i etibarlı sayırlar.
- `cRLentryExtensions`: Hər bir ləğv edilmiş sertifikat üçün spesifik metaməlumatlar, xüsusilə ləğv səbəbi kodu (məsələn, `keyCompromise`, `affiliationChanged`, `cessationOfOperation`).

Miqyaslı Bilmə Problemləri və Bölünmüş Modellər: Nəhəng infrastrukturlarda ləğv edilən sertifikatların sayı artdıqca CRL faylının həcmi meqabaytlarla ölçülür. Bu, şəbəkə trafikini optimallaşdırmaq üçün alternativ strukturların yaranmasına səbəb olmuşdur:

- **Fərq CRL-i:** Yalnız son tam CRL-dən sonra ləğv edilmiş sertifikatları saxlayan kiçik verilənlər çoxluğu. Müştəri əsas siyahını bir dəfə yükləyir və yalnız fərqi sinxronlaşdırır.
- **İndeksləşdirilmiş / Bölünmüş CRL (CDP):** Sertifikatlar seriya nömrələrinə və ya ləğv səbəblərinə görə fərqli qovluqlara paylanır. Beləliklə, müştəri bütün PKI-ın deyil, yalnız müvafiq hissənin siyahısını yükləyir.

CRL-in Fundamental Təhlükəsizlik Boşluğu: Təhlükə Pəncərəsi

CRL mexanizmi **asinxron**dur. Əgər açar t_1 anında kompromat olarsa və CA bunu aşkar edib lokal bazasında ləğv etsə də, növbəti CRL yalnız t_2 anında (nextUpdate) yayımlanacaqdır. $\Delta t = t_2 - t_1$ zaman kəsiyində (hansı ki bu müddət günlərlə ölçülə bilər) hücumçu ləğv edilmiş sertifikatla sistemlərə sızma bilər. Bu boşluq kriptografiyada **təhlükə pəncərəsi** adlanır.

7.2 OCSP və Real Zamanlı Təhlil

CRL-in gətirdiyi asinxronluq və yüksək resurs sərfi problemini həll etmək üçün RFC 6960 standartı çərçivəsində OCSP protokolu yaradılmışdır (Stinson and Paterson, 2018).

Tərif 7.2 (OCSP). OCSP, müştərinin sorğusuna əsasən konkret bir sertifikatın cari vəziyyətini yoxlamaq üçün yoxlama mərkəzi (VA / OCSP cavabverəni) ilə qurulan müştəri-server protokoludur.

Protokolun Riyazi Sorğu-Cavab Strukturu:

- **Sorğu:** Müştəri bütün sertifikatı göndərmir. Şəbəkə yükünü azaltmaq üçün sertifikatın verilənlərindən törəyən CertID strukturunu göndərir:

$$\text{CertID} = (\text{HashAlg}, \text{IssuerNameHash}, \text{IssuerKeyHash}, \text{SerialNumber})$$

- **Cavab:** OCSP cavabverəni cavabı sertifikat verənin açarı və ya id-kp-OCSPSigning EKU-su olan səlahiyyət verilmiş cavabverən açarı ilə imzalaya bilər. unknown cavabverənin həmin sertifikat statusunu bilmədiyini göstərir; bu, “heç vaxt verilməyib” hökmü ilə eyni deyil. Bəzi profillər verilməmiş seriya nömrəsi üçün xüsusi revoked semantikasından istifadə edə bilər (Santesson et al., 2013).

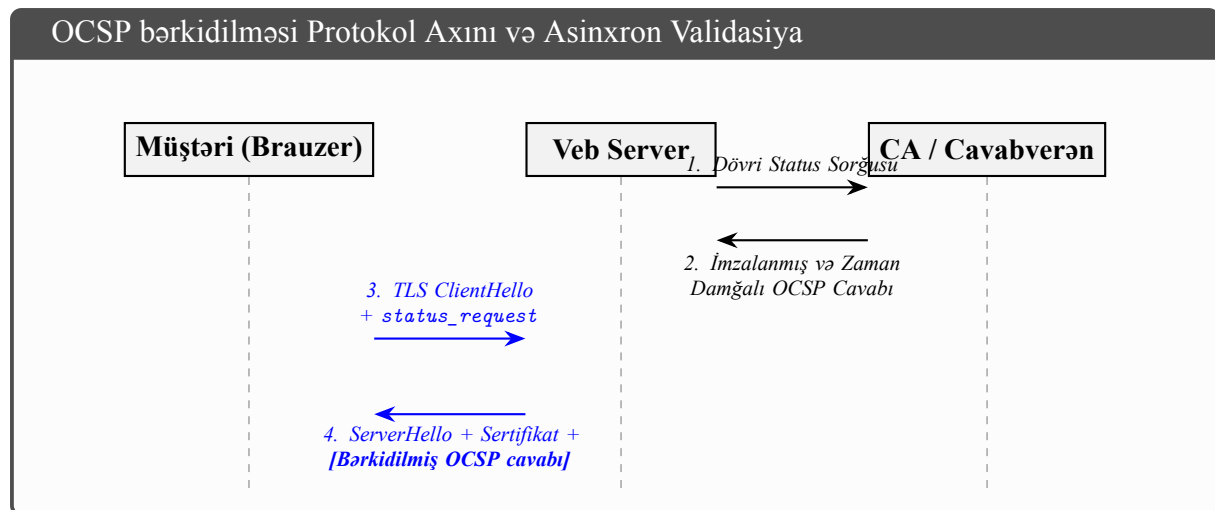
OCSP Arxitekturasının Çatışmazlıqları (Məxfilik və DDoS Riski): Real zamanlı yoxlama təmin edilsə də, OCSP iki ciddi problem yaradır: 1. **Məxfilik itkisi:** Brauzer hər hansı bir HTTPS saytına qoşulduqda, həmin saytın sertifikat seriya nömrəsini CA-ya sorğu olaraq göndərir. Bu, CA-ya istifadəçinin hansı veb-resursları ziyarət etdiyini izləmək imkanı verir. 2. **İnfrastruktur Asılılığı:** Əgər CA-nın OCSP cavabverəni DDoS hücumuna məruz qalarsa və ya əlçatmaz olarsa, brauzerlər ya təhlükəsizliyi qurban verib əlaqəyə davam etməli, ya da qanuni istifadəçiləri bloklamalıdır.

7.3 OCSP Bərkidilməsi (RFC 6066) və Kriptografik Çeviklik

OCSP-nin yaratdığı həm məxfilik, həm də əlavə gediş-gəliş (RTT) gecikmələrini azaltmaq üçün TLS genişlənməsi olan **OCSP bərkidilməsi** tətbiq olunur (Rescorla, 2026).

İş Mexanizmi:

1. Veb server dövrü olaraq cavabverəndən imzalanmış, thisUpdate/nextUpdate pəncərəsi olan OCSP cavabı alır; imzalayan CA və ya səlahiyyət verilmiş cavabverən ola bilər.
2. Müştəri serverə TLS əlaqəsi sorğusu (ClientHello) göndərdikdə status_request uzantısını aktivləşdirir.



Şəkil 4: OCSP bərkidilməsi vasitəsilə üçüncü tərəf asılılığının aradan qaldırılması sxemi.

3. Server müştəriyə öz X.509 sertifikatını göndərərkən, CA-dan aldığı həmin imzalanmış OCSP cavabını da sertifikata əlavə edərək ötürür.
4. Müştəri cavab imzasının səlahiyyətini, sertifikat identifikatorunu və zaman pəncərəsini yoxlayır, sonra lokal ləğv qaydasını tətbiq edir. OCSP bərkidilməsi əlavə sorğunu və məxfilik sızmasını azalda bilər, amma cavab keşlənmişdir və real vaxt zəmanəti deyil.

7.4 Ləğv Mexanizmlərinin Müqayisəli Analizi

Hər üç mexanizmin sistem təhlükəsizliyi və resurs menecmenti baxımından analitik korrelyasiyası aşağıdakı cədvəldə ümumiləşdirilmişdir:

Cədvəl 3: Kriptografik ləğv strukturlarının müqayisəli matrisi.

Sistem Atributu	CRL Metodologiyası	OCSP Protokolu	OCSP bərkidilməsi Sxemi
Statusun Təzəliyi	CRL-in yenilənmə intervalından asılıdır	OCSP cavabının thisUpdate/nextUpdate intervalından asılıdır	Serverin keşlədiyi imzalı cavabın etibarlılıq intervalından asılıdır
İstifadəçi Məxfiliyi	Konkret sayt sorğusu görünür	Cavabverən sorğulanan sertifikatı görə bilər	Müştərinin ayrıca cavabverən sorğusuna ehtiyacı azalır
Şəbəkə Gecikməsi (RTT)	Siyahının endirilməsi və yenilənməsi tələb olunur	Ayrı sorğu əlavə gecikmə yarada bilər	Cavab TLS mesajında ötürüldüyü üçün ayrıca OCSP RTT-si yoxdur
Müştəri Tərəfi Resurs Sərfi	Yüksək (Yaddaşda siyahı analizi)	Aşağı (Minimal paket emalı)	Minimal (Yalnız imza doğrulaması)
CA Qovşağının Yüku	Aşağı (Statik fayl yayımı)	Kritik səviyyədə Yüksək	Çox aşağı (Serverlər yükləri bölüşür)

8 Etibar Modellərinin Topoloji və Funksional Təhlili

Rəqəmsal kimliklərin və açıq açarların doğrulanması sistemlərində etibarın formalaşdırılması, ötürülməsi və miqyaslanması fərqli riyazi və struktur qraf modellərinə söykənir (Stallings, 2017).

8.1 Mərkəzləşdirilmiş iyerarxik PKI etibar modeli

Mərkəzləşdirilmiş model, etibarın tranzitativliyi prinsipinə əsaslanan və kökündə qəti qaydalarla qorunan bir və ya bir neçə kök CA qovşağının dayandığı istiqamətlənmiş iyerarxik ağac strukturudur.

Arxitektura Xüsusiyyətləri:

- **İyerarxik Atribut Ötürülməsi:** Etibar yuxarı qovşaqdan (CA) aşağı qovşağa (Subyekt) rəqəmsal imza zənciri vasitəsilə ötürülür.
- **Deterministik Doğrulama Anbarı:** Brauzerlər və əməliyyat sistemləri istehsal zamanı daxili olaraq ciddi şəkildə yoxlanılmış etibarlı kök anbarı ilə təchiz edilir.
- **Mərkəzləşdirilmiş ləğv:** Sertifikatların vaxtından əvvəl etibarsızlaşdırılması mərkəzi status yoxlama xidməti tərəfindən idarə olunur.

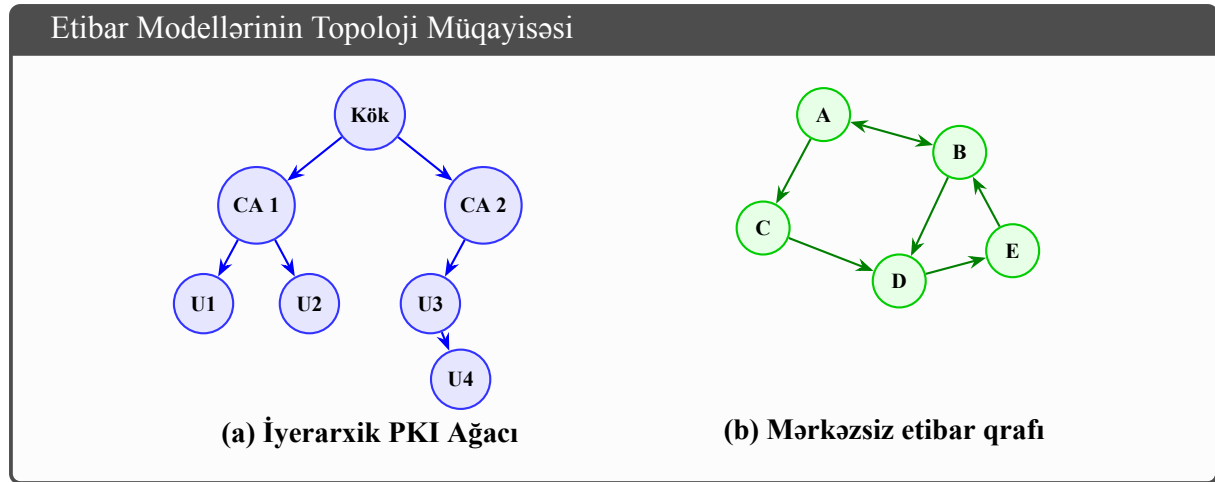
Kriptoqrafik Məhdudiyyətlər və Tək Nasazlıq Nöqtəsi Riski: Mərkəzləşdirilmiş model geniş miqyasda tətbiq və global standartlaşdırma üçün unikal üstünlüklər təmin etsə də, ciddi bir zəifliyə malikdir. Əgər kök və ya yüksək səlahiyyətli aralıq CA-nın gizli açarı (sk_{CA}) kompromat olarsa, həmin sub-ağac tərəfindən imzalanmış bütün rəqəmsal ekosistemin etibarlılığı dərhal çökür (Ferguson et al., 2010).

8.2 Paylanmış Etimad Şəbəkəsi (WoT)

Etimad şəbəkəsi (WoT), hər hansı bir mərkəzi avtoritetə və ya iyerarxiyaya ehtiyac duymayan, PGP və GPG protokollarında reallaşdırılan, mərkəzsizləşdirilmiş istiqamətlənmiş qraf modelidir.

Struktur Mexanizmləri:

- **Qarşılıqlı Sertifikatlaşdırma:** Hər bir istifadəçi həm subyekt, həm də kiçik CA rolunu oynayır. İstifadəçilər real dünyada kimliyini təsdiqlədikləri digər şəxslərin açıq açarlarını öz gizli açarları ilə imzalayırlar.
- **Etibar Dərəcələri:** Etibar binar deyil, dərəcəlidir. PGP arxitekturasında bir açara qismən etibar, tam etibar və ya mütləq şəxsi etibar dərəcəsi təyin edilə bilər.
- **Yerli yoxlama qaydası:** OpenPGP etibar şəbəkəsi modelində açarın etibarlılığı açar sahibinə yerli etibar dərəcələrindən, sertifikasiya yollarından və istifadəçinin sazladığı hədlərdən asılıdır. “Bir tam və ya iki qismən etibarlı imza” bəzi proqramlarda rast gəlinən standart parametrdir, universal kriptoqrafik təhlükə deyil.



Şəkil 5: Mərkəzləşdirilmiş iyerarxik etibar zənciri ilə mərkəzsizləşdirilmiş qarşılıqlı imzalama modelinin müqayisəli topoloji sxemi.

8.3 Praktiki Tətbiq Sahələri və Müasir Standartlar

8.3.1 Müasir TLS/SSL yoxlama növləri və cari vəziyyət

- **Domen yoxlamalı sertifikat (DV):** Avtomatlaşdırılmış ACME protokolu (RFC 8555) vasitəsilə yalnız müvafiq domenin DNS və ya HTTP nəzarətinin sorğuçu tərəfində olub-olmadığını yoxlayan ən geniş yayılmış sertifikat növüdür.
- **Təşkilat yoxlamalı sertifikat (OV):** CA tərəfindən subyektin hüquqi statusu və fiziki varlığının dövlət reyestrləri vasitəsilə rəsmi yoxlanıldığı sertifikat növüdür.
- **Genişləndirilmiş yoxlamalı sertifikat (EV):** Daha geniş hüquqi və təşkilati yoxlama tələb edən sertifikat növüdür. *Akademik qeyd:* Müasir istifadəçi interfeysi qaydalarına əsasən, brauzerlər artıq EV sertifikatları üçün yaşıl ünvan sətrini və şirkət adını birbaşa göstərmir; buna görə EV-in istifadəçiyə görünən fərqi azalıb.

8.3.2 E-Poçt Təhlükəsizliyi və Kod İmzalama

- **S/MIME:** Korporativ mühitdə istifadə olunur. Struktur olaraq mərkəzi X.509 iyerarxiyasına əsaslanır və istifadəçi kimliyini şirkət CA-sı vasitəsilə təsdiqləyir.
- **PGP/GPG:** Fərdi və mərkəzsiz rabitədə istifadə olunur, etimad şəbəkəsi topologiyasına əsaslanır.
- **Kod imzalama:** Əməliyyat sistemlərinin kənar proqram təminatını icra etməzdən əvvəl kodun bütövlüyünü və müəllifini yoxlamaq üçün istifadə etdiyi, zaman damğası genişlənməsi olan X.509 profilidir.

9 Sənaye Səviyyəli Praktiki Təvsiyələr və Kriptografik Çeviklik

Müasir PKI idarəçiliyində və Milli Sertifikat Mərkəzlərinin (CA) layihələndirilməsində NIST və BSI təlimatlarına əsaslanan fundamental prinsiplər aşağıdakı cədvəldə sistemləşdirilmişdir:

Cədvəl 4: PKI və Açar İdarəçiliyi üçün Sənaye Standartları Matrixi.

Kategoriya	Sənaye Norması (Kvant Öncəsi)	Arxitektura Səbəb və Təhlükəsizlik Marjası
Açar Uzunluğu	RSA-2048 təqribən 112-bit, RSA-3072 təqribən 128-bit klassik təhlükəsizlik səviyyəsinə uyğunlaşdırılır; ECC üçün P-256 və ya Curve25519 ailəsi təqribən 128-bit səviyyə verir	Ölçü təhlükə modeli, məlumatın qorunma müddəti, qarşılıqlı işləmə və tətbiq olunan normativ profil üzrə seçilməlidir; RSA-4096 universal tələb deyil.
Sertifikat Ömrü	İctimai TLS əbunəçi sertifikatları üçün CA/Browser Forum qrafikinə uyğun olaraq 15 mart 2026-dan maksimum 200 gün; özəl PKI profilləri ayrı qaydalarla idarə olunur	Qısa ömür kompromatın təsir pəncərəsini azalda və avtomatlaşdırılmış yenilənməni təşviq edə bilər; kök və aralıq CA müddətləri ayrıca risk qiymətləndirilməsi tələb edir (CA/Browser Forum, 2026).
Ləğv Strategiyası	Profilə görə CRL, OCSP, OCSP bərkidilməsi və ya qısaömürlü sertifikatlar	Seçim relying-party davranışı, cavabın təzəliyi, fail-open/fail-closed qaydası, məxfilik və əlçatanlıq tələbləri ilə birlikdə qiymətləndirilməlidir.
Kök CA Rejimi	Riskə uyğun qorunan, adətən oflayn saxlanan kök açar; uyğun sertifikatlı HSM və çoxşəxslə əməliyyat nəzarəti	Oflayn arxitektura uzaq şəbəkə hücumu səthini azaldır, lakin fiziki, əməliyyat və təchizat zənciri risklərini aradan qaldırmır.
Audit və Monitoring	İctimai TLS profilləri üçün Certificate Transparency (CT) jurnalları və müstəqil monitoring	CT buraxılışı avtomatik dayandırır; sertifikatları müşahidə olunan edir və yanlış buraxılışın aşkarlanması və cavab tədbirləri üçün sübut yaradır.

10 Nümunə Məsələlər və Çalışmalar

Cəhddən əvvəl

Əvvəlcə sertifikat və yol yoxlaması sübutlarını özünüz qeyd edin; sadə termin siyahısı tam cavab sayılmır. Müəllim üçün cavab açarı yalnız ilkin cəhddən sonra açılmalıdır.

Çalışma 10.1. Açar idarəçiliyinin əsas çətinliklərini sadalayın.

Çalışma 10.2. Açarın həyat dövrünün əsas mərhələlərini izah edin.

Çalışma 10.3. Brauzer `api.example.az` ünvanına qoşulur. Server sertifikatında `subjectAltName=DNS:www.basicConstraints=CA:FALSE, keyUsage=digitalSignature, extendedKeyUsage=serverAuth`

və qüvvədə olan tarix intervalı verilib. Hansı yoxlamalar keçir, hansı yoxlama bağlantını rədd edir? Qərarı konkret sahələrlə əsaslandırın.

Çalışma 10.4. *Sertifikat ləğv mexanizmləri olan CRL və OCSP strukturları arasında hansı fundamental fərqlər var?*

Çalışma 10.5. *OCSP bərkidilməsi texnologiyasının arxitektura və təhlükəsizlik baxımından üstünlükləri nələrdir?*

Çalışma 10.6. *Kök CA və aralıq CA arasında hansı fərqlər var? İyerarxik PKI modelində aralıq CA-lardan istifadə edilməsinin səbəbi nədir?*

Çalışma 10.7. *Mərkəzləşdirilmiş PKI modelini və mərkəzsizləşdirilmiş etimad şəbəkəsi (WoT) modelini müqayisə edin.*

Çalışma 10.8. *Server Son → Aralıq-B zəncirini göndərir; müştərinin anbarında Kök-A var. Aralıq-B sertifikatı Kök-A tərəfindən imzalanıb, lakin `basicConstraints=CA:FALSE` göstərir. Müştərinin path builder və yol yoxlaması addımlarını ayırın, yekun qəbul/rədd qərarını verin və etibar zənciri ilə sertifikat zəncirinin fərqi göstərin.*

11 Müəllim üçün cavab açarı

1. **Açar idarəçiliyinin əsas çətinlikləri:** Genişlənmə bilmə, kriptografik təhlükəsizlik marjası, sistemin etibarlılığı, fəlakət anında açar itkisi riskləri, dövrü açar yenilənməsi və effektiv ləğv mexanizmlərinin qurulması.
2. **Açar həyat dövrünün mərhələləri:** Yaradılma, təhlükəsiz paylanma, saxlanma və aktiv istifadə, yenilənmə, ləğv, arxivləşdirmə və məhv.
3. **Sertifikat artefaktının təhlili:** Tarix, CA:FALSE, digitalSignature və serverAuth serverin son sertifikatı üçün uyğundur. Lakin gözlənilən `api.example.az` adı SAN-dakı `www.example.az` ilə uyğun gəlmir; host adı yoxlaması bağlantını rədd edir. Subyekt/CN məlumatı SAN mövcud olduqda bu uyğunsuzluğu aradan qaldırmır.
4. **CRL və OCSP arasındakı fərqlər:**
 - **Sertifikat ləğv siyahısı (CRL):** CA tərəfindən dövrü olaraq imzalanıb yayımlanan statik bir ləğv siyahısıdır. Şəbəkənin oflayn olduğu ssenarilərdə işləyə bilər, lakin siyahı böyüdükcə böyük ölçü (trafik) problemi yaradır.
 - **OCSP:** Konkret sertifikat üçün imzalı status cavabı verən sorğu-cavab protokoludur. Cavabın təzəliyi `thisUpdate/nextUpdate` sahələri ilə məhdudlaşır; ayrıca sorğu əlaqə və məxfilik xərci yarada bilər.
5. **OCSP bərkidilməsi üstünlükləri:**
 - **Məxfilik:** CA serveri istifadəçinin hansı resursa daxil olduğunu öyrənmə bilmir.
 - **Sürət və Performans:** Müştəri tərəfində əlavə şəbəkə gecikməsi (+1 RTT) yaranmır, status birbaşa TLS bağlantısı daxilində gəlir.
 - **Yükün Azaldılması:** CA-in infrastrukturunu milyonlarla müştərinin sorğusundan azad olur, çünki status cavabı server tərəfindən keşlənir.
6. **Kök CA və Aralıq CA fərqləri:** Kök CA PKI ierarxiyasının etibar lövbəridir və adətən nadir, çoxşəxslı mərasimlər üçün oflayn saxlanılır. Aralıq CA kök və ya başqa CA tərəfindən imzalanır və gündəlik sertifikat buraxılışını icra edə bilər. Bu arxitektura kök açarın istifadəsini azaltmağa, kompromat riskini lokallaşdırmağa və təşkilati seqmentasiya yaratmağa kömək edir; konkret rejim sertifikat siyasətindən asılıdır.
7. **PKI və etimad şəbəkəsinin müqayisəsi:** PKI modeli mərkəzləşdirilmişdir və tamamilə rəsmi Sertifikat Mərkəzlərinin (CA) etibarlılığına əsaslanır (məsələn, HTTPS/TLS). Etimad şəbəkəsi (WoT) isə mərkəzsizləşdirilmişdir; istifadəçilər bir-birlərinin rəqəmsal kimliklərini çarpaz şəkildə imzalayaraq etibar şəbəkəsi qururlar (məsələn, PGP/GPG). PKI global miqyasda və sənayedə standartdır, WoT isə daha lokal və spesifik icmalarda istifadə olunur.
8. **Sertifikat yolunun artefakt üzrə yoxlanılması:**
 - (a) Yol qurucusu serverin göndərdiyi son və Aralıq-B obyektlərini yerli Kök-A etibar lövbərinə bağlayan namizəd yol qurur; kök sertifikatın server tərəfindən göndərilməsi tələb olunmur.

- (b) Yol yoxlaması imzaları və tarixləri yoxlasa da, sertifikat verən aralıq sertifikat üçün `basicConstraints=CA:TRUE` tələb edir.
- (c) Aralıq-B-də `CA:FALSE` olduğuna görə yol rədd edilir; imzanın Kök-A ilə kriptografik doğrulanması bu siyasət xətasını kompensasiya etmir.
- (d) *Sertifikat zənciri* ötürülən/qurulan obyektlərdir; *etibar zənciri* isə sertifikata güvənən tərəfin etibar lövbəri və siyasətə əsaslanan qərarıdır.

12 Xülasə

Bu mühazirədə aşağıdakı əsas anlayışları öyrəndik:

- **Açar idarəçiliyi:** Açarların generasiyası, paylanması, təhlükəsiz saxlanması, istifadəsi, rotasiyası, ləğvi və məhvi proseslərinin bütövlüyü (Stinson and Paterson, 2018).
- **PKI (Açıq Açar İnfrastruktur):** Açıq açarların etibarlı şəkildə idarə edilməsi, paylanması və rəqəmsal sertifikatlarla bağlanması üçün lazım olan aparat, proqram təminatı və hüquqi qaydalar toplusu (Stallings, 2017).
- **X.509 sertifikatları:** Müəyyən bir açıq açarı konkret şəxsin və ya serverin kimliyinə bağlayan, səlahiyyətli CA tərəfindən rəqəmsal olaraq imzalanmış standartlaşdırılmış sənəd (Ferguson et al., 2010).
- **Sertifikat Mərkəzləri (CA):** Rəqəmsal dünyada pasport idarəsi rolunu oynayan, sertifikatları imzalayan və verən yüksək təhlükəsizlikli etibarlı qurumlar (Katz and Lindell, 2020).
- **Sertifikat zəncirləri:** Son istifadəçi sertifikatından başlayaraq etibarlı Kök CA-ya qədər uzanan, etibarın ötürülməsini təmin edən sertifikatlar ardıcılığı (Stallings, 2017).
- **Ləğv mexanizmləri:** Kompromat olunmuş açarla bağlı sertifikatın statusunu yaymaq üçün tətbiq edilən CRL, vaxtla məhdud imzalı cavab verən OCSP və ayrıca müştəri sorğusuna ehtiyacı azaldan OCSP bərkidilməsi mexanizmləri (Paar et al., 2024; Rescorla, 2026).
- **Etibar modelləri:** CA iyerarxiyasına əsaslanan mərkəzləşdirilmiş (PKI) və qarşılıqlı zəmanətə əsaslanan paylanmış etimad şəbəkəsi arxitekturaları (Ferguson et al., 2010).

Əsas nəticə: Asimmetrik kriptografiya açıq açarların etibarlı şəkildə paylanmasını tələb edir. PKI bu problemi həll edərək açıq açarları sertifikatlar vasitəsilə istifadəçilərə bağlayır. Sertifikatların etibarlılığı CA-lar tərəfindən təmin edilir. Ləğv mexanizmləri (CRL, OCSP, OCSP bərkidilməsi) kompromat olunmuş sertifikatların istifadəsinin qarşısını alır. Müasir internetin təhlükəsiz işləməsi PKI-yə əsaslanır.

References

- E. Barker. Recommendation for key management: Part 1 – general. Technical Report NIST Special Publication 800-57 Part 1 Revision 5, National Institute of Standards and Technology, 2020. <https://doi.org/10.6028/NIST.SP.800-57pt1r5>.

- CA/Browser Forum. Baseline requirements for the issuance and management of publicly-trusted certificates, 2026. URL <https://cabforum.org/baseline-requirements-documents/>. Accessed: 2026.
- D. Cooper, S. Santesson, S. Farrell, S. Boeyen, R. Housley, and W. Polk. Internet x.509 public key infrastructure certificate and certificate revocation list (crl) profile, May 2008. <https://www.rfc-editor.org/info/rfc5280>.
- N. Ferguson, B. Schneier, and T. Kohno. *Cryptography Engineering: Design Principles and Practical Applications*. Wiley, Indianapolis, 2010. ISBN: 978-0470474242.
- J. Katz and Y. Lindell. *Introduction to Modern Cryptography*. CRC Press, Boca Raton, 3rd edition, 2020. ISBN: 978-0815354369.
- A. J. Menezes, P. C. van Oorschot, and S. A. Vanstone. *Handbook of Applied Cryptography*. CRC Press, 1996.
- C. Paar, J. Pelzl, and T. Güneysu. *Understanding Cryptography: A Textbook for Students and Practitioners*. Springer, Berlin, Heidelberg, 2nd edition, 2024. ISBN 978-3-662-68393-4. doi: 10.1007/978-3-662-68394-1.
- E. Rescorla. The transport layer security (tls) protocol version 1.3. RFC 9846, RFC Editor, July 2026. URL <https://www.rfc-editor.org/info/rfc9846>.
- S. Santesson, M. Myers, R. Ankney, A. Malpani, S. Galperin, and C. Adams. X.509 internet public key infrastructure online certificate status protocol - ocsp, June 2013. <https://www.rfc-editor.org/info/rfc6960>.
- W. Stallings. *Cryptography and Network Security: Principles and Practice*. Pearson, 7 edition, 2017.
- D. R. Stinson and M. B. Paterson. *Cryptography: Theory and Practice*. CRC Press, Boca Raton, 4th edition, 2018. ISBN: 978-1138197015.